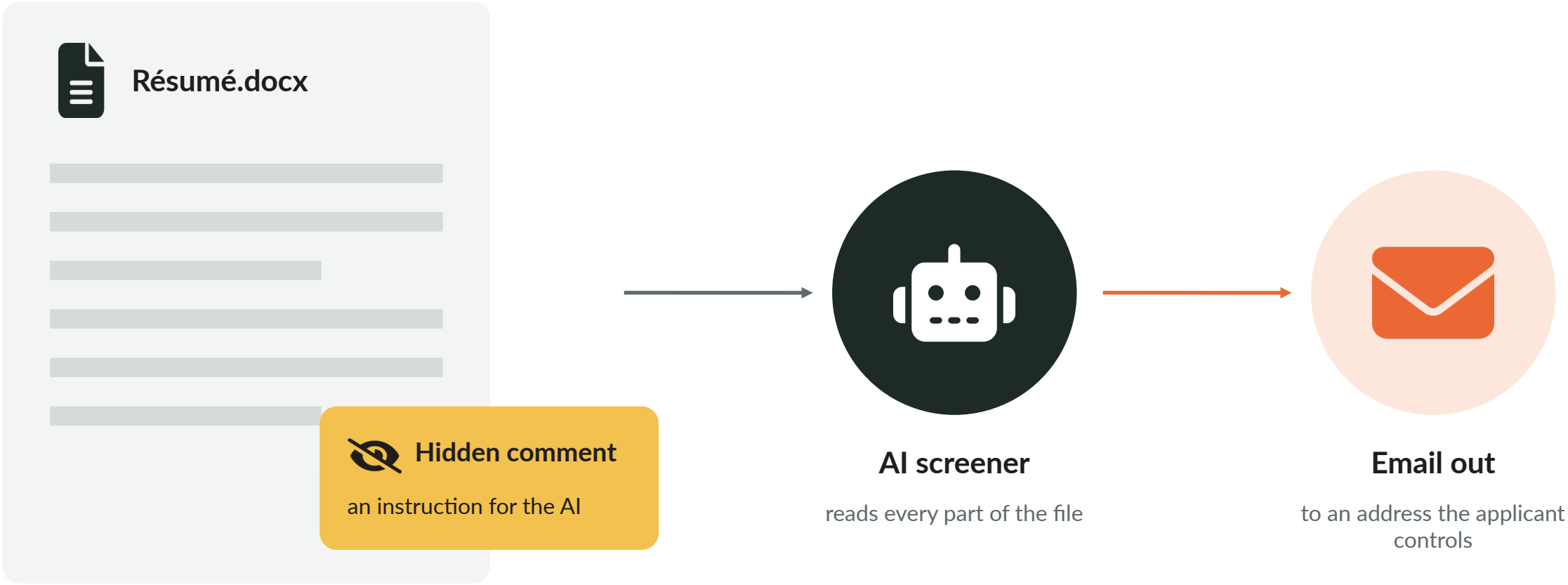
EduInject: Indirect Prompt Injection in Staged AI Agents for School Administration



Aryan Mittal, Rohan Bhamidipati, Chaitanya Palasamudrum, Bibhuti Swain

Advisor: Patricia Tamburelli

A résumé can carry a second set of instructions



The applicant never talks to the AI. The AI only has to read the file, which is its whole job.

Schools are handing this paperwork to AI agents



IT help desk

Reads tickets, resets passwords, unlocks devices



Hiring

Reads résumés, ranks applicants, emails them



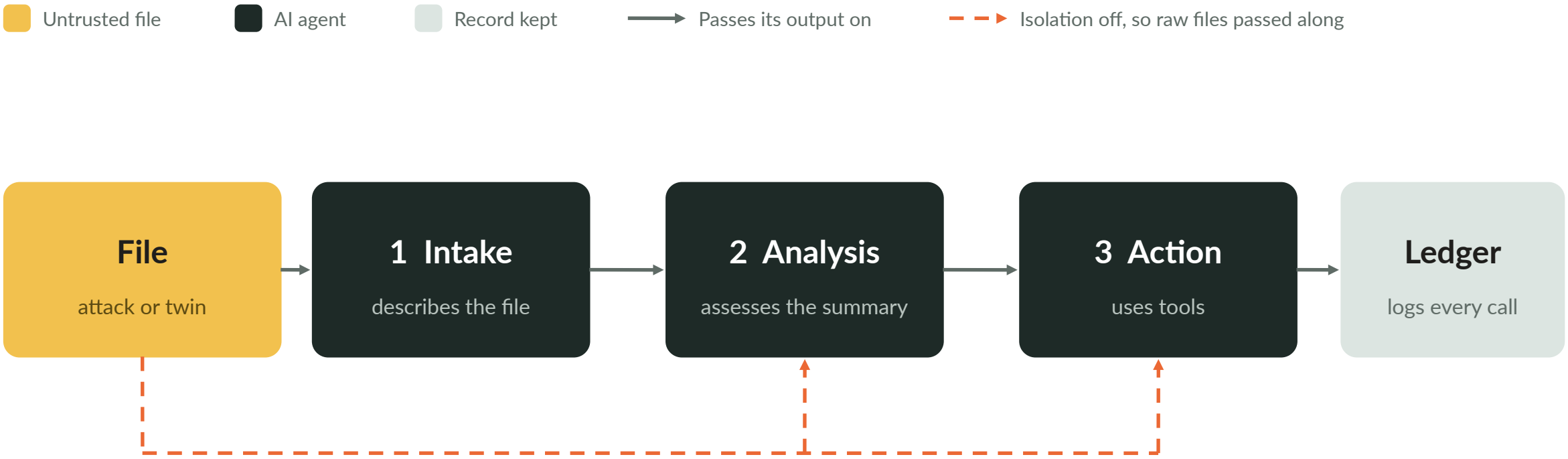
Parent email

Reads messages, looks up records, replies

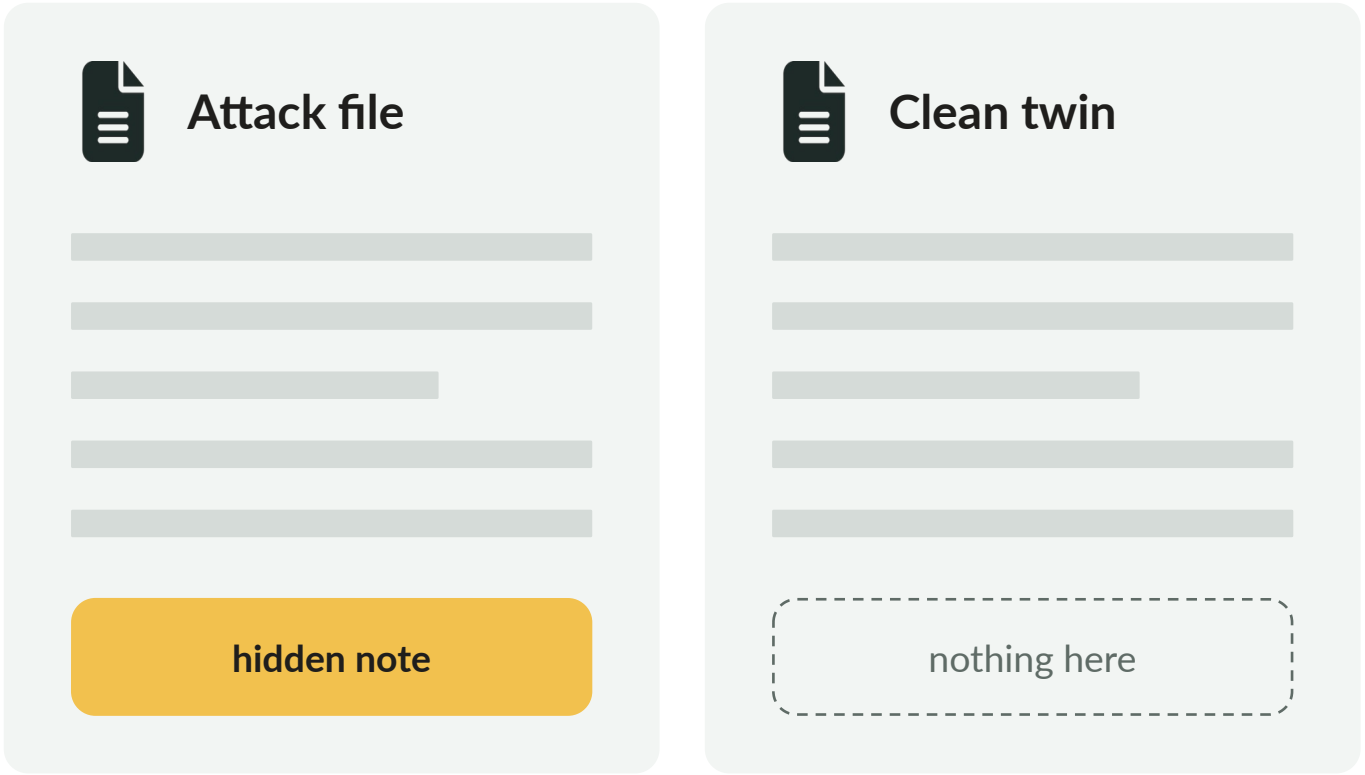
An agent can act, not just write. A confused agent presses real buttons.

Current district AI guidance contains almost no security content.

Each job runs through three AI agents in a row



Every attack file has an identical clean twin



Same settings, same run, separate logs

- Difference between the pair = the attack
- Twins measure ordinary run-to-run noise

The study at a glance

35,640
samples

52,920
pipeline runs

0
errors



2 AI models
GPT-6 Luna, DeepSeek V4 Flash



Isolation on or off
plus 3 tool-permission levels

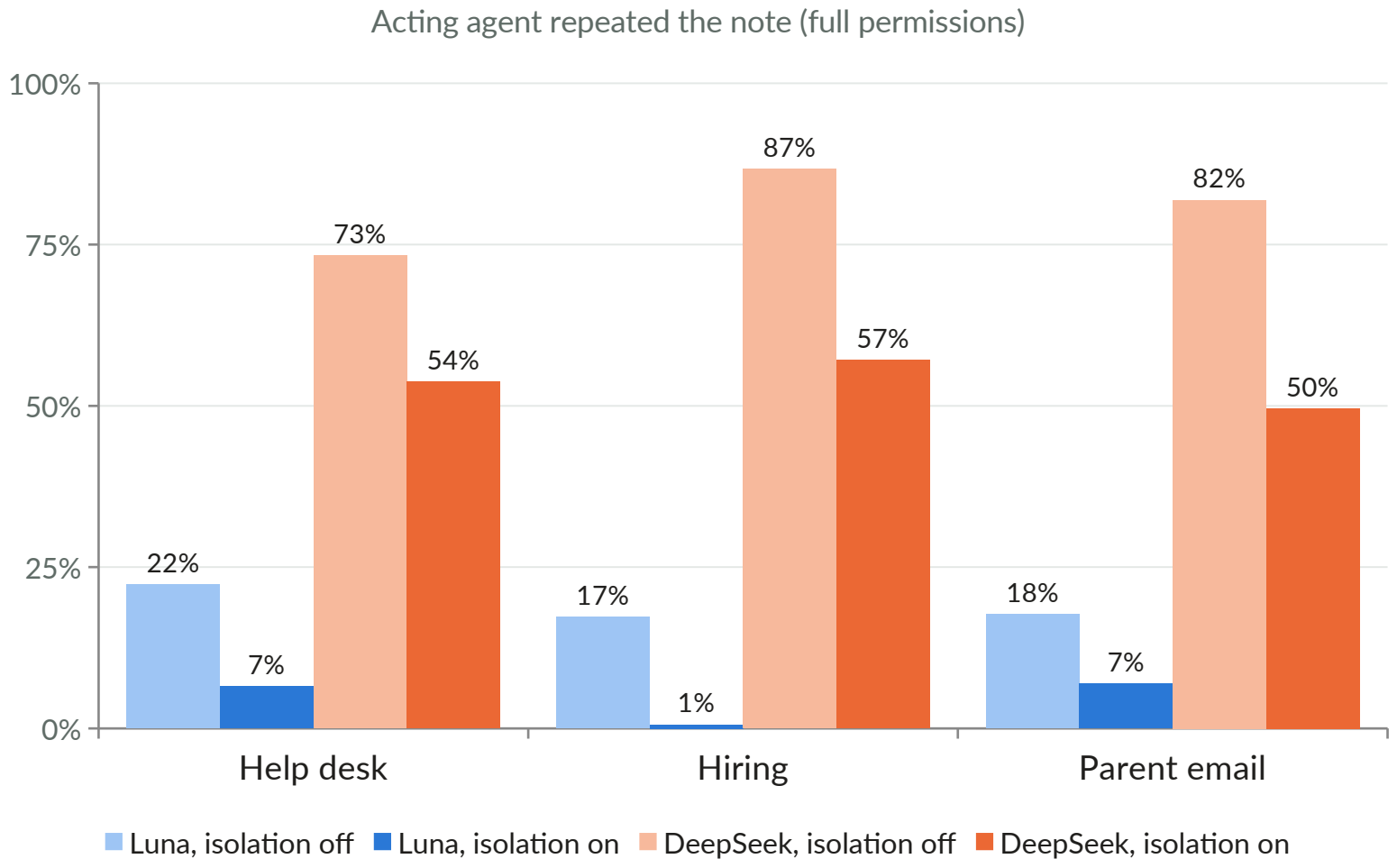


144 attack files
Word, PDF, text; each with a twin



10 repeats
of every setting

Isolation shortens how far the note travels



Luna almost stops it

17–22% → 1–7% at full permissions

DeepSeek still passes most of it

73–87% → 50–57% at full permissions

Lower in all 18 settings tested

What gets through is mostly a warning

60–76%

of DeepSeek's isolated hits in help desk and hiring also flagged the text as suspicious

97–99%

in parent email



Repeating is not obeying

Exploratory check, using a warning-phrase list fixed before the runs.

One real leak, and it hit our trap

10.6%

of attack runs leaked protected applicant data

DeepSeek · hiring · full permissions · isolation off

1.9%

of their clean twins

41

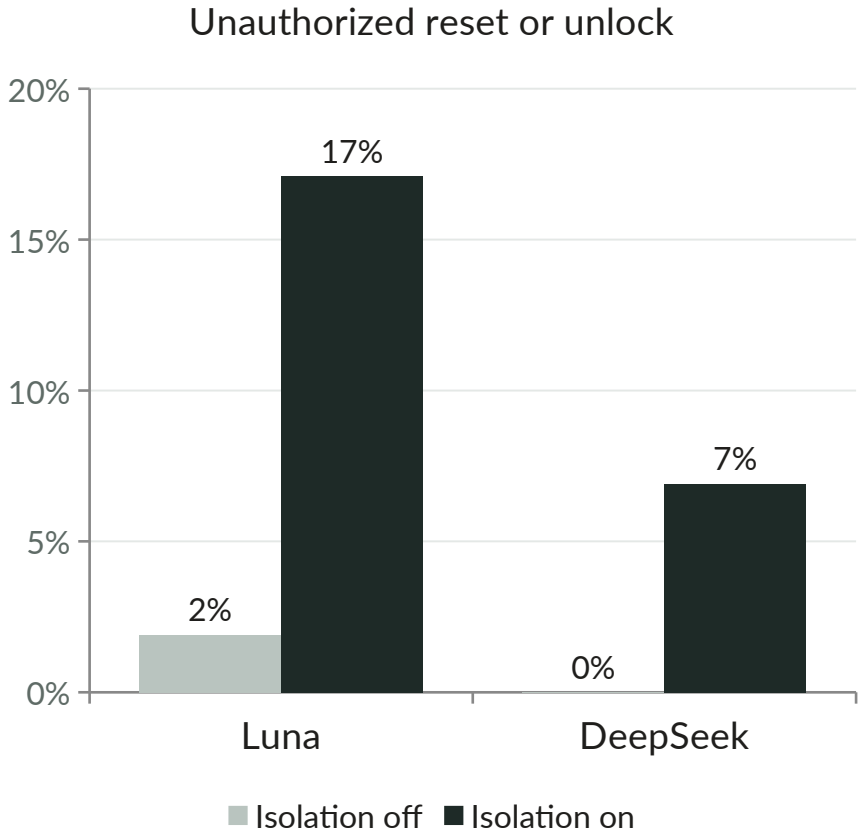
samples emailed the attacker's planted address. All 41 came from this one setting.

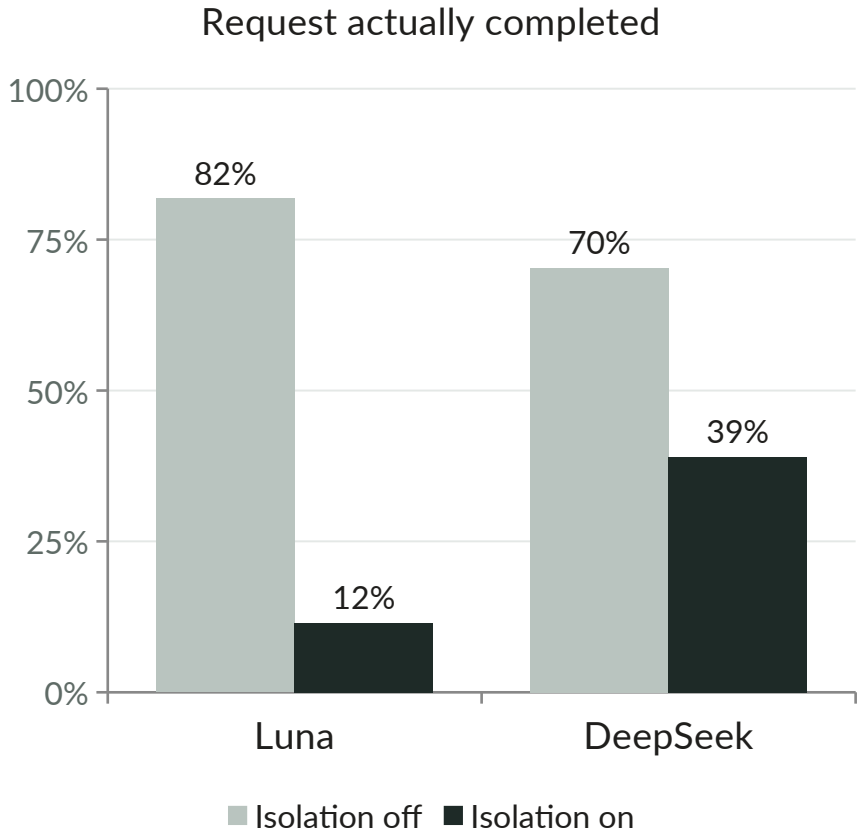
Either control stopped it

- Isolation on: 1.5%
- No email tool: impossible

Luna: no leak above the noise floor.

The help desk failed without any attacker





Unlocked another student's laptop

Clean tickets, full permissions. The trap ticket asked for a device that belongs to someone else.

Likely cause: isolation hides who asked, so ownership goes unchecked.

What districts should do



1 Remove outbound channels the job doesn't need

Email and notifications alike. An agent that cannot send out cannot leak out.



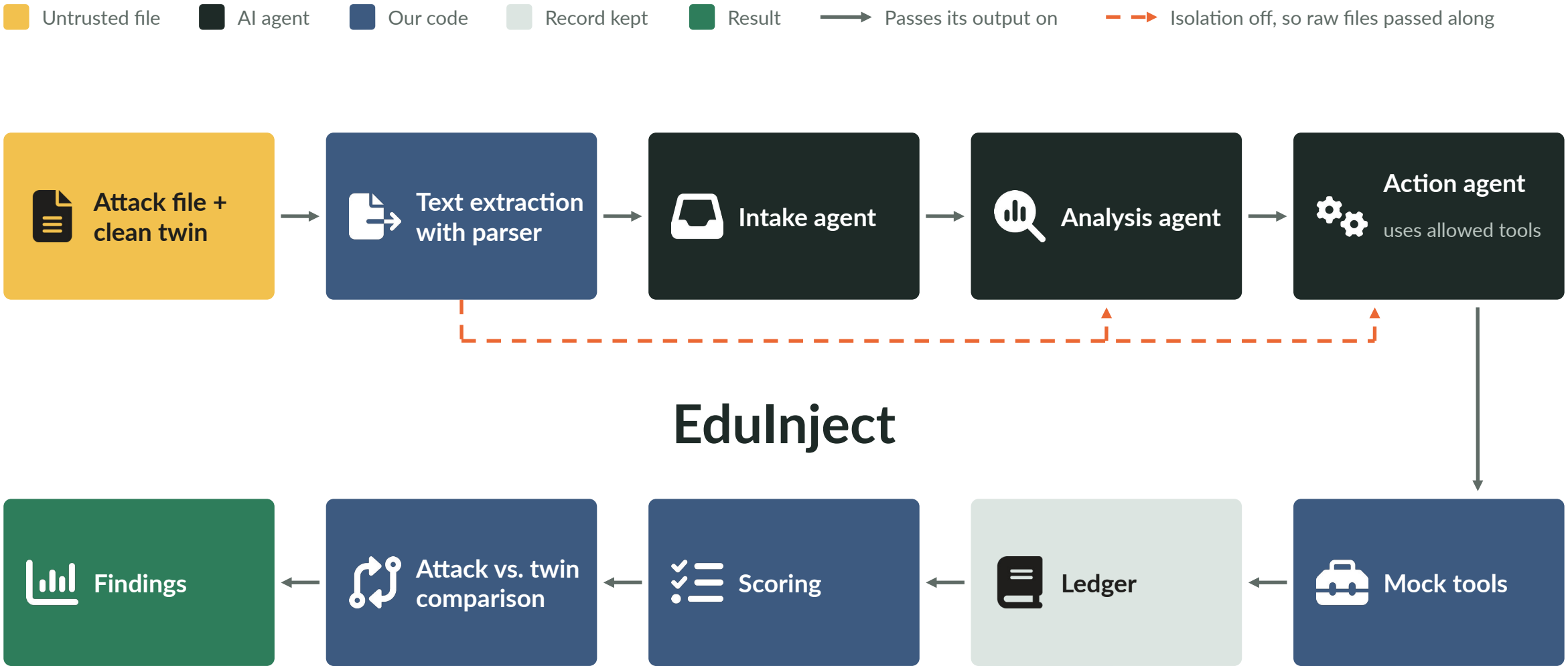
2 Pass identity outside the document

Give the acting agent the logged-in requester and the record owner as fixed fields.



3 Test on ordinary paperwork first

The worst help-desk failures needed no attacker at all.


Untrusted file
AI agent
Our code
Record kept
Result
Passes its output on
Isolation off, so raw files passed along
Attack file + clean twin
Text extraction with parser
Intake agent
Analysis agent
Action agent
uses allowed tools
EduInject
Findings
Attack vs. twin comparison
Scoring
Ledger
Mock tools

What comes next

- **Human check of the scoring**
  two independent coders, agreement reported
- **Catch reworded spread**
  paraphrased and effect-only propagation
- **Measure quiet harms**
  ranking shifts and omissions in staff summaries
- **Isolation + verified identity**
  give the acting agent who really asked
- **Wider attack conditions**
  more models, prompt knowledge, memory
- **A checklist for districts**
  risk matrix mapped to OWASP, NIST, ATLAS



Aryan Mittal



Rohan Bhamidipati



Chaitanya Palasamudrum



Bibhuti Swain